



Directive NIS2 – Vers une cybersécurité renforcée en Europe

Face à la hausse exponentielle des cyberattaques ciblant les infrastructures critiques, l'Union Européenne a développé une réponse coordonnée à travers la directive NIS2. Cette directive fondatrice vise à uniformiser et renforcer la cybersécurité dans l'ensemble de l'UE.

Cette présentation vous permettra de comprendre les enjeux majeurs de cette réglementation et d'anticiper les mesures nécessaires pour assurer conformité à votre organisation.



Sommaire

3 *Cadre Général*

Aperçu de la conformité

23 *Mesures Techniques*

Infrastructure et réseau

43 *Gestion des Incidents*

Continuité des opérations

63 *Frameworks et Normes*

Structurer la conformité

13 *Gouvernance Cybersécurité*

Structure de gestion

33 *Sécurité des Applications*

Protection applicative

53 *Documentation et Preuve*

Conformité prouvée

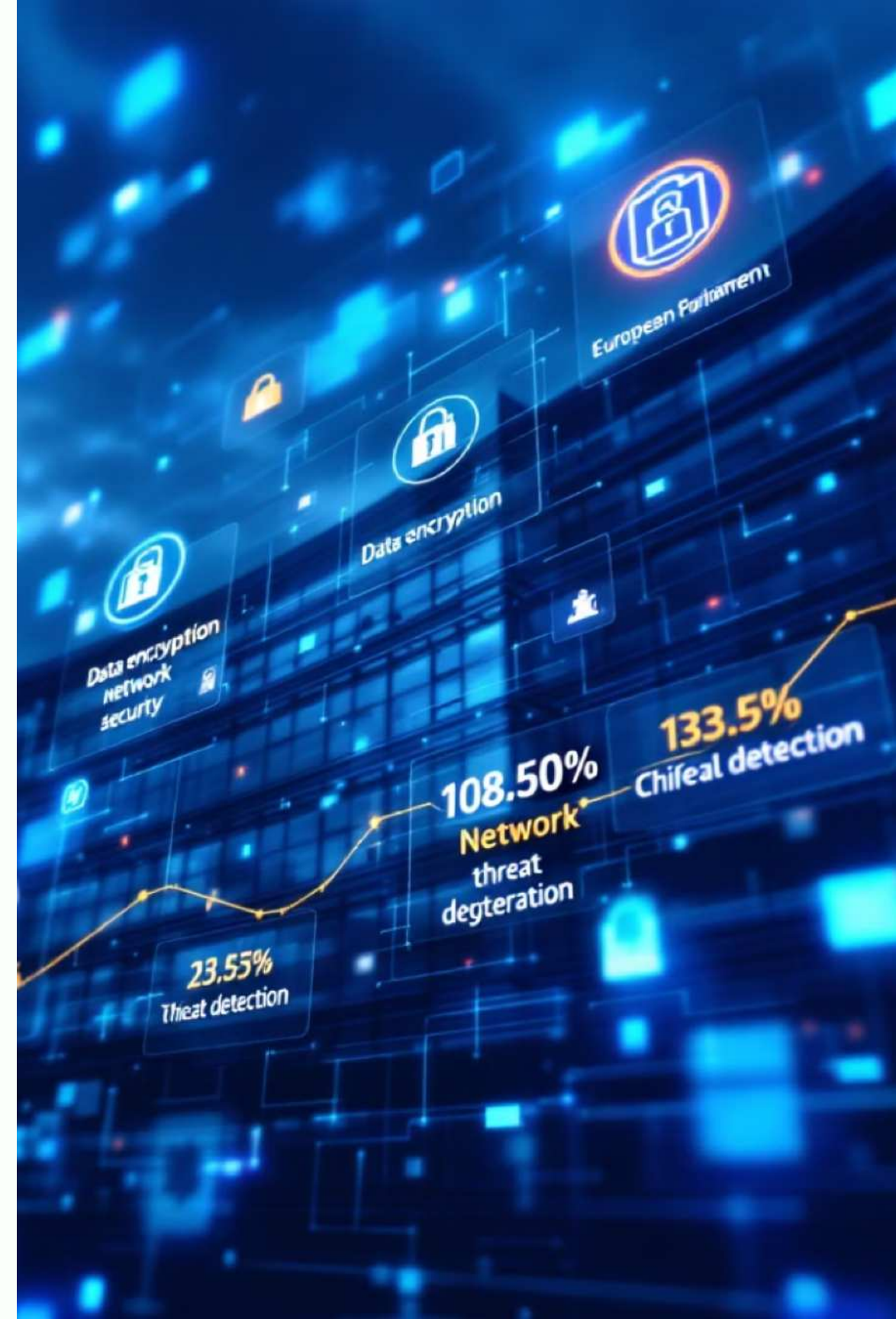


Directive NIS2 – Cadre général

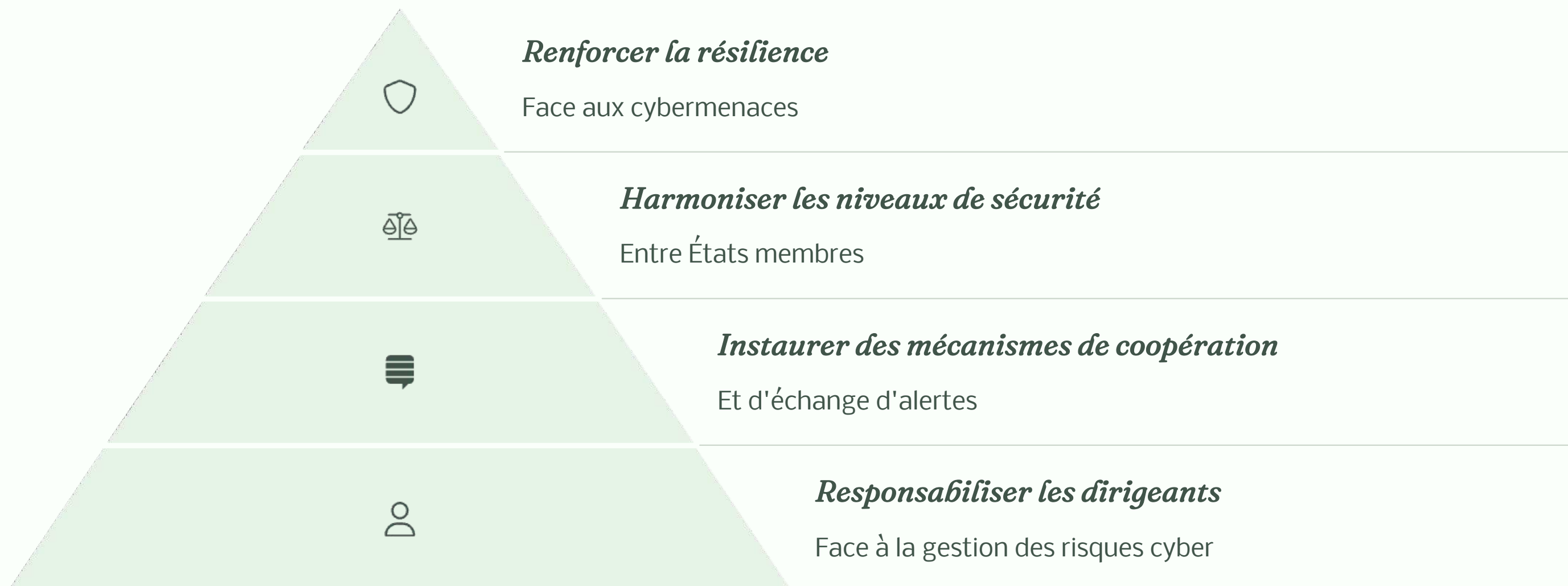
Contexte réglementaire



La directive NIS2 succède à la première version qui présentait des lacunes importantes dans son application. Cette nouvelle mouture renforce considérablement les exigences et harmonise les pratiques à l'échelle européenne pour créer un cadre de cybersécurité plus robuste et cohérent.



Objectifs stratégiques



La directive NIS2 vise à créer un écosystème européen de cybersécurité plus robuste en établissant des standards communs et en favorisant la collaboration entre les différents acteurs. Elle place également une responsabilité accrue sur les dirigeants d'entreprises, qui devront désormais s'impliquer directement dans la stratégie de cybersécurité.

Qui est concerné ?

Entités essentielles

- Énergie
- Transport
- Santé
- Infrastructures numériques
- Eau
- Banques

Entités importantes

- Fabricants critiques
- Services numériques
- Chimie
- Alimentation
- Traitement des déchets

Critères de taille

Entreprises de plus de 50 salariés ou
CA > 10 millions €

Les opérateurs de services critiques
peuvent être concernés même s'ils
sont plus petits

Le périmètre d'application de NIS2 est considérablement élargi par rapport à la première directive. De nombreux secteurs d'activité sont désormais explicitement visés, avec une distinction entre entités essentielles et importantes, soumises à des niveaux d'exigence adaptés.



Résumé des obligations clés



Mesures techniques et organisationnelles

Mise en œuvre de politiques et mesures adaptées aux risques identifiés



Auditabilité et documentation

Traçabilité complète du système et documentation des actions de sécurité



Notification des incidents

Pré-alerte dans un délai de 24h et rapport complet sous 72h pour les incidents majeurs



Supervision active

Surveillance continue du niveau de sécurité et implication explicite des organes de direction

Les obligations imposées par NIS2 couvrent l'ensemble du cycle de vie de la sécurité, depuis la prévention jusqu'à la gestion des incidents. L'accent est mis sur la capacité à détecter, réagir et notifier rapidement tout événement significatif, tout en maintenant une documentation exhaustive des mesures mises en place.



Gouvernance & responsabilités

Responsabilité personnelle

Les conseils d'administration et dirigeants sont tenus personnellement responsables de la cybersécurité de leur organisation

Formation obligatoire

Obligation de former la direction à la cybersécurité et aux enjeux spécifiques de l'entreprise

Intégration stratégique

La gestion du risque cyber doit être intégrée dans la stratégie globale de l'entreprise

Traçabilité des décisions

Toutes les décisions en matière de sécurité doivent être documentées et justifiables

NIS2 marque un tournant majeur en plaçant explicitement la responsabilité de la cybersécurité au niveau des instances dirigeantes. Les décideurs ne peuvent plus déléguer entièrement cette responsabilité aux équipes techniques et doivent s'impliquer activement dans la gouvernance des risques cyber.

Sécurité du SI – Infrastructures et réseaux



Authentification

MFA sur tous les accès critiques et gestion centralisée des identités (IAM)



Cloisonnement

Séparation des zones réseau (VLAN, bastion, DMZ) pour limiter la propagation des attaques



Mises à jour

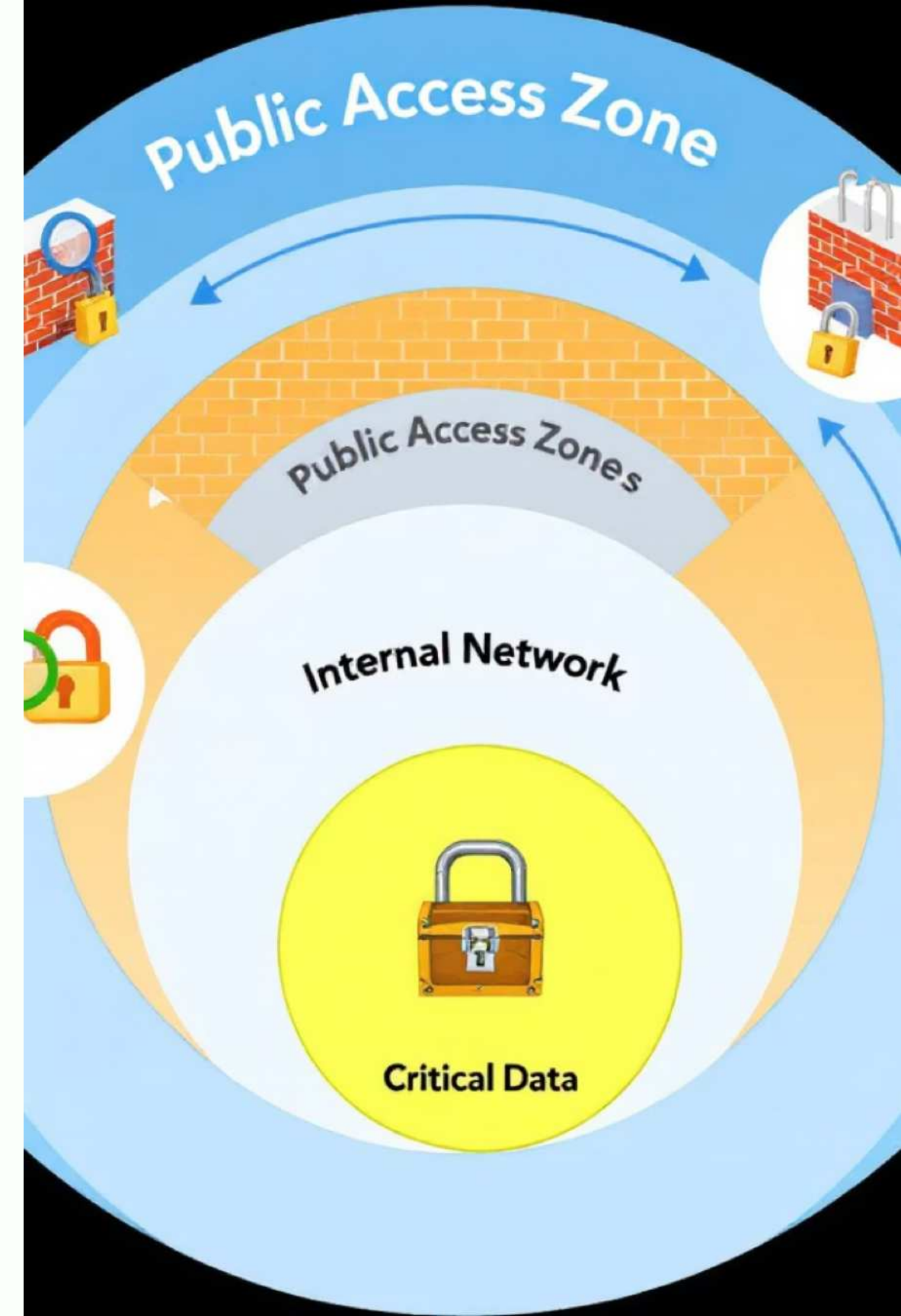
Patch management régulier des OS et applicatifs pour corriger les vulnérabilités



Protection des données

Sauvegardes hors-ligne testées régulièrement et chiffrement des données au repos et en transit

Les exigences techniques de NIS2 couvrent l'ensemble des bonnes pratiques de sécurité des infrastructures. La directive impose la mise en place de mesures concrètes pour protéger les systèmes d'information, avec un accent particulier sur la protection des accès, la segmentation réseau et la résilience des données.





Gestion des incidents



Détection

Identification d'un incident majeur via les systèmes de supervision



Notification initiale

Déclaration à l'autorité nationale dans un délai de 24h (pré-alerte)



Rapport détaillé

Rapport initial sous 72h, suivi d'un rapport final si nécessaire



Documentation

Tenue d'un registre des incidents et exercices réguliers (simulations de crise)

La gestion des incidents constitue un pilier central de NIS2. Les organisations doivent non seulement mettre en place des procédures documentées et testées, mais également respecter des délais stricts de notification aux autorités. Cette approche vise à améliorer la réactivité collective face aux cybermenaces.

Sanctions et contrôles

10M€

Amende maximale

Ou 2% du chiffre d'affaires mondial annuel, selon le montant le plus élevé

100%

Contrôles

Possibilité d'audit complet par les autorités nationales (ex : ANSSI en France)

24h

Délai critique

Pour la notification des incidents majeurs, sous peine de sanctions

Le régime de sanctions prévu par NIS2 est particulièrement dissuasif, avec des amendes pouvant atteindre des montants considérables. Au-delà des sanctions financières, les autorités disposent de pouvoirs étendus, incluant la possibilité de suspendre l'activité en cas de non-conformité majeure et même d'engager la responsabilité individuelle des dirigeants.



Plan d'action recommandé



Évaluer l'applicabilité

Identifier si votre organisation est soumise à NIS2



Analyser la maturité

Réaliser des audits et diagnostics de cybersécurité



Planifier

Élaborer une feuille de route priorisée et mettre à jour les politiques



Sensibiliser

Former toutes les parties prenantes et tester les processus

Pour se conformer efficacement à NIS2, les organisations doivent adopter une approche méthodique. Il est recommandé de s'appuyer sur des référentiels reconnus comme ISO/IEC 27001/27002, EBIOS Risk Manager, SecNumCloud, NIST Cybersecurity Framework ou encore les CIS Benchmarks pour structurer sa démarche de mise en conformité.

L'implication de la direction et la sensibilisation de l'ensemble des collaborateurs sont des facteurs clés de succès pour intégrer durablement les exigences de NIS2 dans la culture de l'entreprise.



Gouvernance de la cybersécurité

Cadre de pilotage stratégique et opérationnel du risque cyber.

Cette présentation explore les éléments fondamentaux de la gouvernance exigée par NIS2, depuis la politique de sécurité jusqu'aux rôles et responsabilités des acteurs clés, en passant par les processus essentiels de gestion des risques et des incidents.

Rôle central de la gouvernance

La gouvernance cyber constitue l'élément structurant fondamental dans la gestion du risque numérique. Elle établit un cadre cohérent permettant d'organiser et de piloter efficacement les activités de cybersécurité au sein de l'organisation.

La directive NIS2 introduit une **responsabilité explicite de la direction** dans la supervision des mesures de cybersécurité. Cette approche garantit l'alignement entre les objectifs de sécurité, la stratégie globale de l'entreprise, les exigences de conformité et l'efficacité opérationnelle.

Une gouvernance solide représente la base indispensable pour le déploiement et le pilotage cohérent des politiques de cybersécurité à tous les niveaux de l'organisation.

- | | | |
|--|--|---|
|  <p><i>Structure organisée</i>
Établit un cadre cohérent pour la gestion du risque numérique</p> |  <p><i>Responsabilité de la direction</i>
Supervision directe des mesures de cybersécurité</p> |  <p><i>Alignement stratégique</i>
Harmonisation entre sécurité, stratégie et conformité</p> |
|--|--|---|

Politique de sécurité du SI (PSSI)

La Politique de Sécurité du Système d'Information constitue le document cadre essentiel qui définit l'ensemble des règles de sécurité applicables au sein de l'organisation. Elle établit les principes directeurs et les exigences fondamentales en matière de protection des actifs informationnels.

Formellement validée par la direction générale, la PSSI est pilotée par le Responsable de la Sécurité des Systèmes d'Information (RSSI). Ce document stratégique doit être régulièrement mis à jour, au minimum annuellement ou après tout incident majeur affectant la sécurité de l'organisation.

Gestion des accès

Définition des règles d'authentification, d'autorisation et de contrôle d'accès aux ressources informatiques de l'entreprise.

Classification des données

Catégorisation des informations selon leur sensibilité et définition des mesures de protection appropriées pour chaque niveau.

Usage des ressources IT

Encadrement de l'utilisation des équipements, logiciels et services informatiques mis à disposition des collaborateurs.

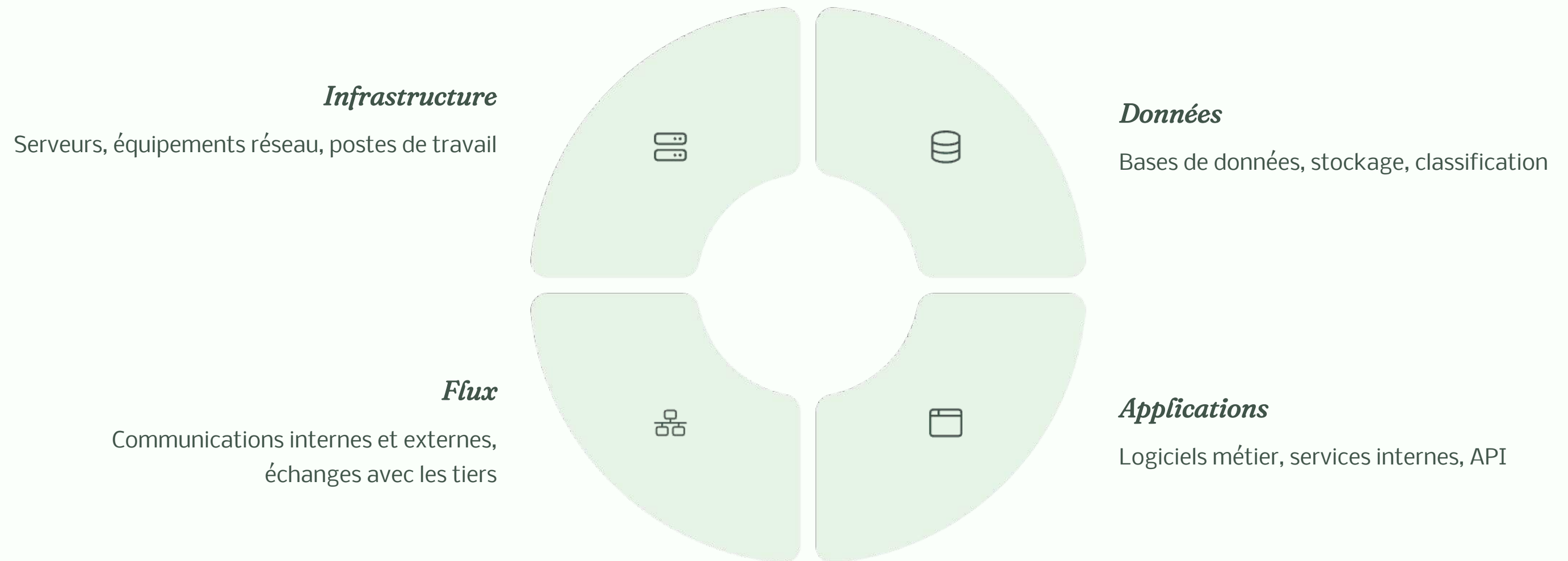
Journalisation et sauvegardes

Spécification des exigences en matière de traçabilité des actions et de protection des données contre les pertes.

Cartographie des actifs et des flux

La cartographie des actifs et des flux constitue un élément fondamental de la gouvernance de cybersécurité. Son objectif principal est d'établir une connaissance précise et exhaustive des composants techniques et des flux d'information qui constituent le système d'information de l'organisation.

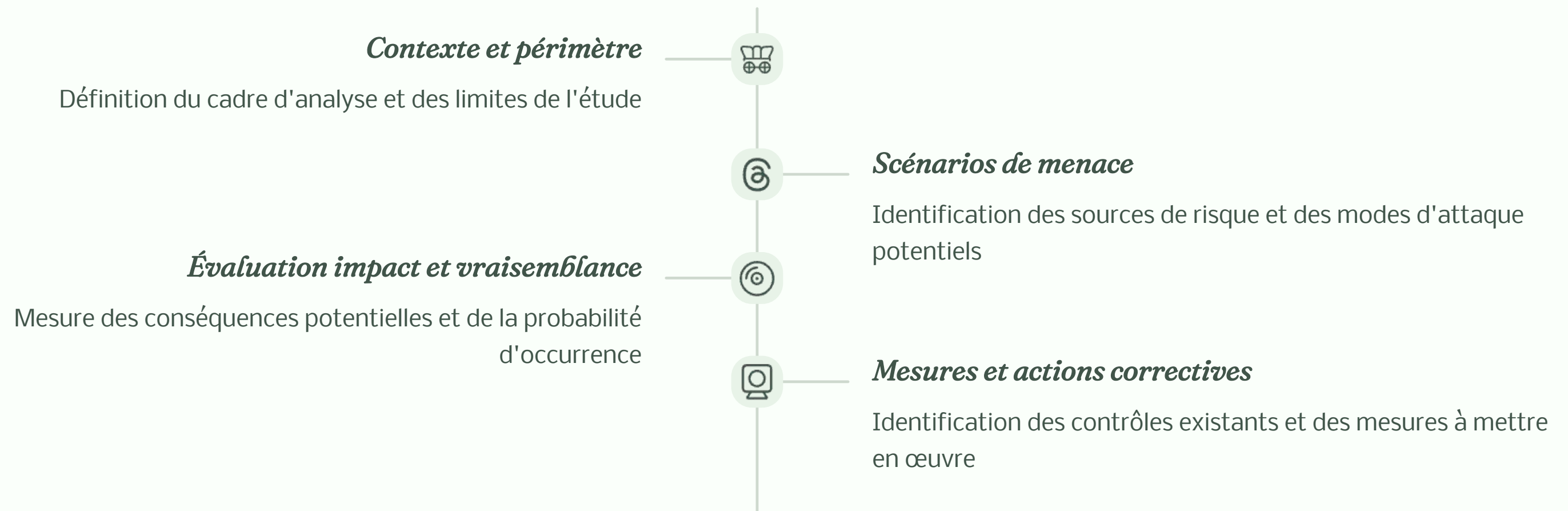
Cette cartographie doit inclure l'ensemble des éléments critiques tels que les serveurs, les infrastructures réseau, les applications métier et les bases de données. Elle doit également documenter les flux d'information, qu'ils soient internes (entre différentes zones du SI) ou externes (vers des tiers, des API ou des services cloud).



Analyse de risques (EBIOS RM, ISO 27005)

L'analyse de risques constitue une démarche méthodique permettant d'identifier, hiérarchiser et maîtriser les risques cyber auxquels l'organisation est exposée. Elle s'appuie sur des méthodologies reconnues comme EBIOS Risk Manager ou ISO 27005 pour garantir une approche structurée et exhaustive.

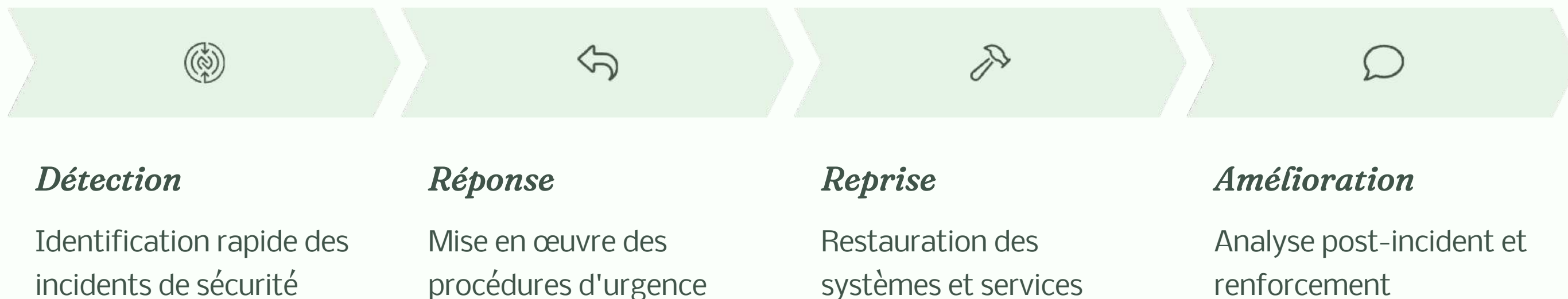
Cette analyse doit être actualisée au minimum annuellement ou après tout changement majeur dans l'environnement informatique ou le contexte de menaces. Elle permet d'orienter les investissements en sécurité vers les risques les plus critiques pour l'organisation.



Gestion des incidents, PRA et PCA

La gestion des incidents et la planification de la continuité représentent des éléments cruciaux de la gouvernance cyber exigée par NIS2. Le Plan de Reprise d'Activité (**PRA**) se concentre sur les aspects techniques avec des délais courts, tandis que le Plan de Continuité d'Activité (**PCA**) adopte une approche plus fonctionnelle, centrée sur le maintien des services essentiels.

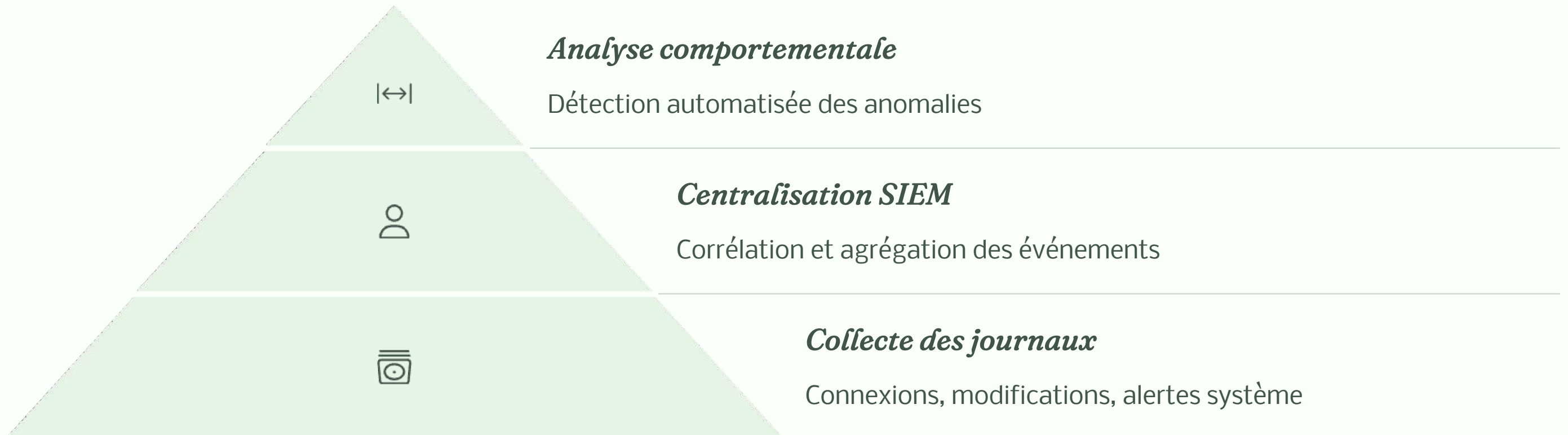
La directive NIS2 impose que ces plans soient rigoureusement documentés, régulièrement testés et formellement versionnés. Les procédures de gestion de crise doivent être clairement formalisées et immédiatement disponibles en cas d'incident. Un registre détaillé des incidents doit également être maintenu à jour.



Journalisation et supervision

La journalisation et la supervision constituent des piliers essentiels de la gouvernance cyber, répondant à plusieurs objectifs fondamentaux : garantir l'auditabilité des systèmes, permettre la détection précoce des incidents, fournir des éléments de preuve en cas d'investigation et assurer la conformité réglementaire.

Les journaux doivent être conservés sur une période adaptée à leur criticité, généralement entre 6 et 24 mois. L'intégration avec un **SIEM** (Security Information and Event Management) ou une plateforme centralisée permet d'optimiser l'analyse et la corrélation des événements de sécurité.



Auditabilité du système

L'auditabilité représente la capacité d'une organisation à démontrer concrètement la mise en œuvre effective des mesures de sécurité prévues dans ses politiques. Cette dimension est particulièrement valorisée dans le cadre de la directive NIS2, qui met l'accent sur la responsabilité et la transparence.

Une documentation rigoureuse et à jour constitue le socle de cette auditabilité. Elle doit couvrir l'ensemble des éléments structurants de la gouvernance cyber : la Politique de Sécurité des Systèmes d'Information, les plans de continuité et de reprise d'activité, les analyses de risques, ainsi que les mécanismes de journalisation et les tableaux de bord de pilotage.

Documentation formalisée

Ensemble des politiques, procédures et plans de sécurité clairement documentés et accessibles

Traçabilité des actions

Journalisation complète des événements de sécurité et conservation des preuves numériques

Audits réguliers

Vérifications internes ou externes de la conformité aux politiques et aux exigences réglementaires

Rôle du RSSI ou responsable désigné

Le Responsable de la Sécurité des Systèmes d'Information (RSSI) constitue le pilote opérationnel de la cybersécurité au sein de l'organisation. Son rôle est central dans la mise en œuvre effective de la gouvernance exigée par la directive NIS2.

Pour exercer pleinement ses missions, le RSSI doit disposer d'un **mandat clair**, de **moyens** adaptés aux enjeux de l'organisation et d'une **légitimité interne** reconnue par l'ensemble des parties prenantes. Son positionnement dans l'organigramme doit refléter l'importance stratégique accordée à la cybersécurité.



Définition des politiques

Élaboration et mise à jour de la PSSI et des directives de sécurité



Suivi des incidents

Supervision de la gestion des événements de sécurité et coordination des réponses



Animation de la gouvernance

Pilotage des comités de sécurité et reporting à la direction



Interface réglementaire

Relation avec les autorités comme l'ANSSI et suivi de la conformité

Synthèse gouvernance de la cybersécurité

La gouvernance représente véritablement la **colonne vertébrale de la cybersécurité** dans le cadre de la directive NIS2. Elle structure l'ensemble des dispositifs de protection et garantit leur cohérence avec les objectifs stratégiques de l'organisation.

Pour se conformer efficacement aux exigences de NIS2, les organisations doivent établir une feuille de route claire, priorisant les actions fondamentales. Cette démarche structurée doit être engagée rapidement pour assurer une mise en conformité avant l'échéance d'octobre 2024.



Nommer un RSSI légitime

Désigner un responsable avec mandat et moyens



Formaliser la PSSI

Établir le cadre documentaire de référence



Cartographier et analyser

Identifier actifs, flux et risques associés



Tester PRA/PCA

Valider les procédures de continuité

Mesures techniques exigées

Cette section se concentre sur les moyens techniques concrets attendus pour assurer la conformité avec la directive NIS2, en mettant l'accent sur la sécurisation de l'infrastructure et du réseau.

Sont présentées ici les différentes mesures techniques adaptées au niveau de risque, couvrant des aspects essentiels comme le contrôle d'accès, la segmentation réseau, le durcissement des systèmes, et bien d'autres éléments permettant d'assurer une cybersécurité efficace.





Contrôle d'accès & gestion des identités

L'authentification multifacteur (**MFA**) devient obligatoire pour tous les accès aux systèmes sensibles, renforçant considérablement la sécurité des connexions.

La mise en place d'un système **IAM** (Identity & Access Management) permet de centraliser la gestion des autorisations, tandis que le cloisonnement des comptes à privilèges limite les risques d'exploitation.



MFA obligatoire

Pour tous les accès sensibles et critiques



IAM centralisé

Gestion unifiée des identités et autorisations



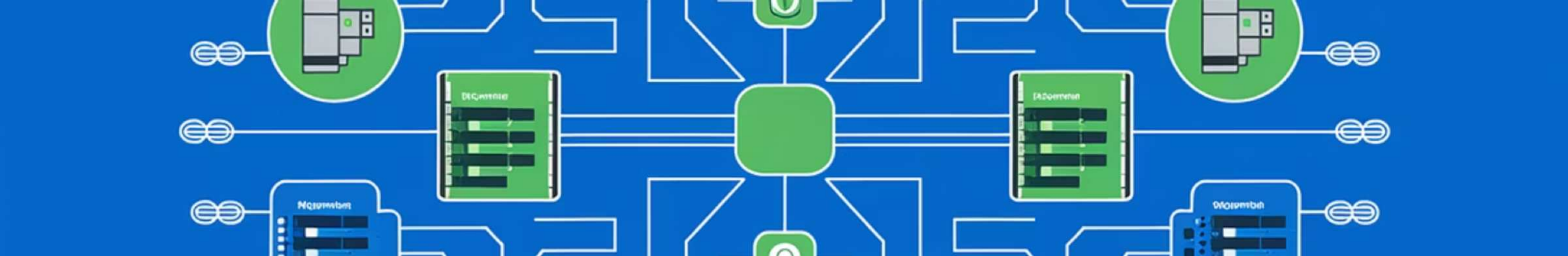
Cloisonnement des privilèges

Séparation stricte des comptes administratifs



Revue périodique

Vérification régulière des droits d'accès



Segmentation réseau

La segmentation réseau constitue une mesure de sécurité fondamentale exigée par NIS2, avec la création de **zones de confiance** distinctes pour limiter la propagation des attaques.

L'utilisation de **VLAN** permet de séparer efficacement les environnements (production, développement, test), tandis que des **pare-feux internes** avec des règles de filtrage strictes contrôlent les flux entre ces zones.



Durcissement des systèmes

Le durcissement des systèmes est une exigence fondamentale de NIS2, imposant que tous les systèmes soient **mis à jour régulièrement** pour corriger les vulnérabilités connues.

Cette démarche implique également la suppression des **services inutiles**, l'application d'une **configuration minimale sécurisée** (selon les CIS Benchmarks), la désactivation des comptes par défaut et la limitation des ports et services ouverts.

Mises à jour régulières

Application systématique des correctifs de sécurité sur tous les systèmes

Suppression des services inutiles

Élimination de tous les composants logiciels non essentiels

Configuration minimale sécurisée

Application des recommandations CIS Benchmarks pour tous les systèmes

Limitation des accès

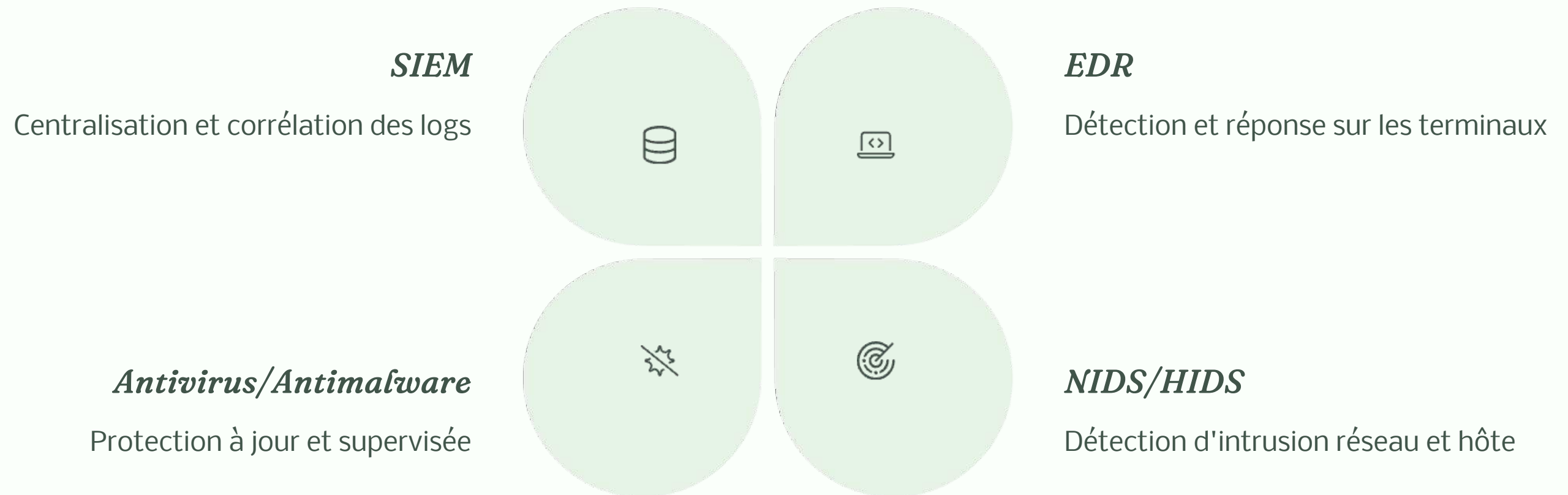
Désactivation des comptes par défaut et restriction des ports ouverts



Surveillance & détection

La directive NIS2 exige la mise en place de systèmes de surveillance avancés, notamment l'intégration d'un **SIEM** pour centraliser et corrélérer les journaux d'événements de sécurité.

Le déploiement de **solutions EDR** (Endpoint Detection & Response) et de systèmes de détection d'intrusion (**NIDS/HIDS**) permet d'identifier rapidement les comportements anormaux et les tentatives d'attaque.



Chiffrement des données

NIS2 impose un chiffrement robuste des données, tant **au repos** qu'**en transit**. Les données stockées doivent être protégées via des solutions comme LUKS ou BitLocker, tandis que les communications doivent utiliser TLS 1.2 ou supérieur.

Une **gestion sécurisée des clés** est essentielle, avec l'utilisation recommandée de modules HSM. Les protocoles cryptographiques obsolètes ou faibles (SSL, TLS 1.0) sont strictement interdits.

Données au repos

Utilisation de LUKS, BitLocker ou équivalent pour chiffrer les données stockées sur les systèmes.

- Disques durs
- Bases de données
- Fichiers sensibles

Données en transit

Protection des communications via TLS 1.2+ ou VPN pour sécuriser les échanges d'informations.

- Communications web
- Transferts de fichiers
- Accès distants

Gestion des clés

Mise en place d'une infrastructure sécurisée pour la gestion des clés cryptographiques.

- HSM recommandé
- Rotation périodique
- Accès restreint



Sauvegardes sécurisées

La directive NIS2 exige des sauvegardes **régulières, testées et automatisées** pour garantir la continuité d'activité en cas d'incident. Ces copies doivent être stockées **hors ligne** ou dans des **coffres numériques** pour les protéger des attaques.

La vérification périodique de la **restauration complète** est obligatoire pour s'assurer de l'efficacité du dispositif. Le chiffrement des sauvegardes et l'isolation des systèmes dédiés complètent ce dispositif de protection.



Sauvegardes régulières

Exécution automatisée selon une fréquence définie dans la politique de sauvegarde

2

Stockage sécurisé

Conservation hors ligne ou dans des coffres numériques isolés



Tests de restauration

Vérification périodique de la capacité à restaurer intégralement les systèmes



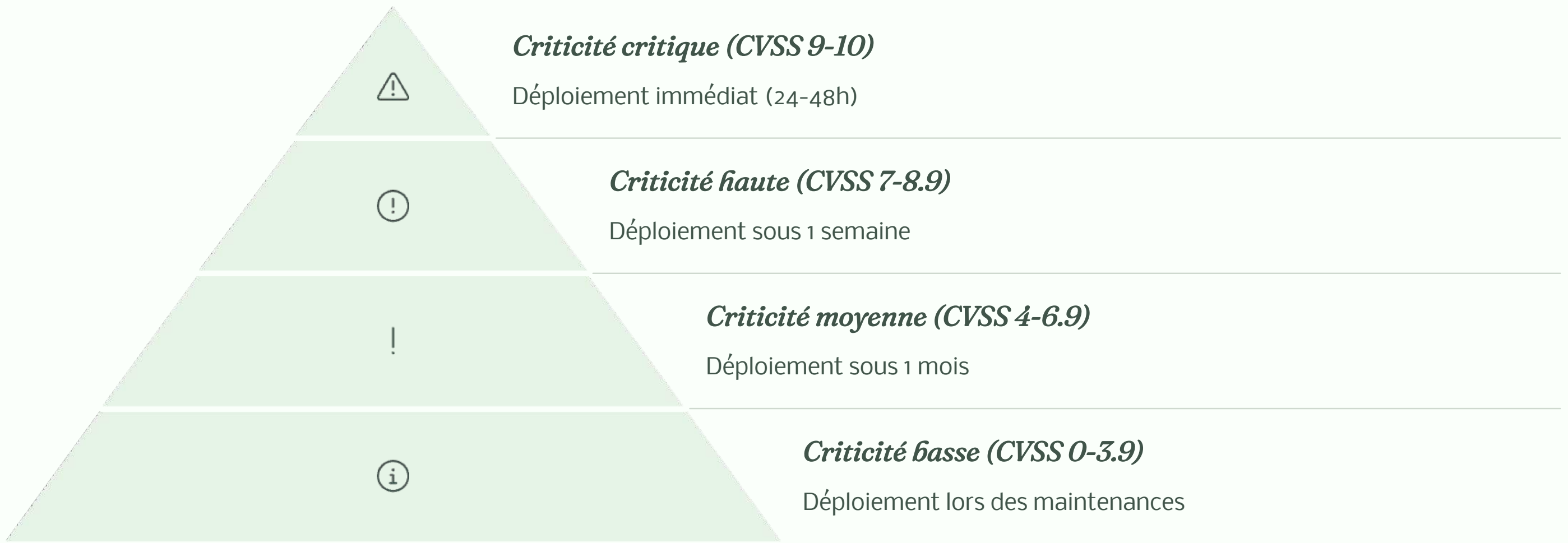
Protection renforcée

Chiffrement des sauvegardes et isolation des systèmes dédiés

Gestion des correctifs

NIS2 impose un déploiement **rapide des correctifs après leur publication** pour limiter la fenêtre d'exposition aux vulnérabilités. Un suivi automatisé des vulnérabilités via des scanners ou flux RSS doit être mis en place.

L'application des patches doit suivre une priorisation **selon la criticité CVSS**, avec maintien d'un **registre des correctifs appliqués**. Une attention particulière doit être portée aux composants open source souvent négligés.





Authentification & politique de comptes

La directive NIS2 recommande fortement la mise en place d'un **SSO couplé à une MFA** pour simplifier et renforcer l'authentification des utilisateurs. Une politique de mots de passe robuste doit être appliquée, définissant des exigences strictes de longueur et complexité.

L'**expiration automatique** des comptes inactifs et la **révision périodique** des comptes et rôles sont essentielles. Tous les accès doivent respecter le principe du **moindre privilège**, limitant les droits au strict nécessaire.

2

Facteurs d'authentification

Minimum requis pour les accès sensibles (MFA)

90

Jours

Fréquence maximale de révision des comptes privilégiés

30

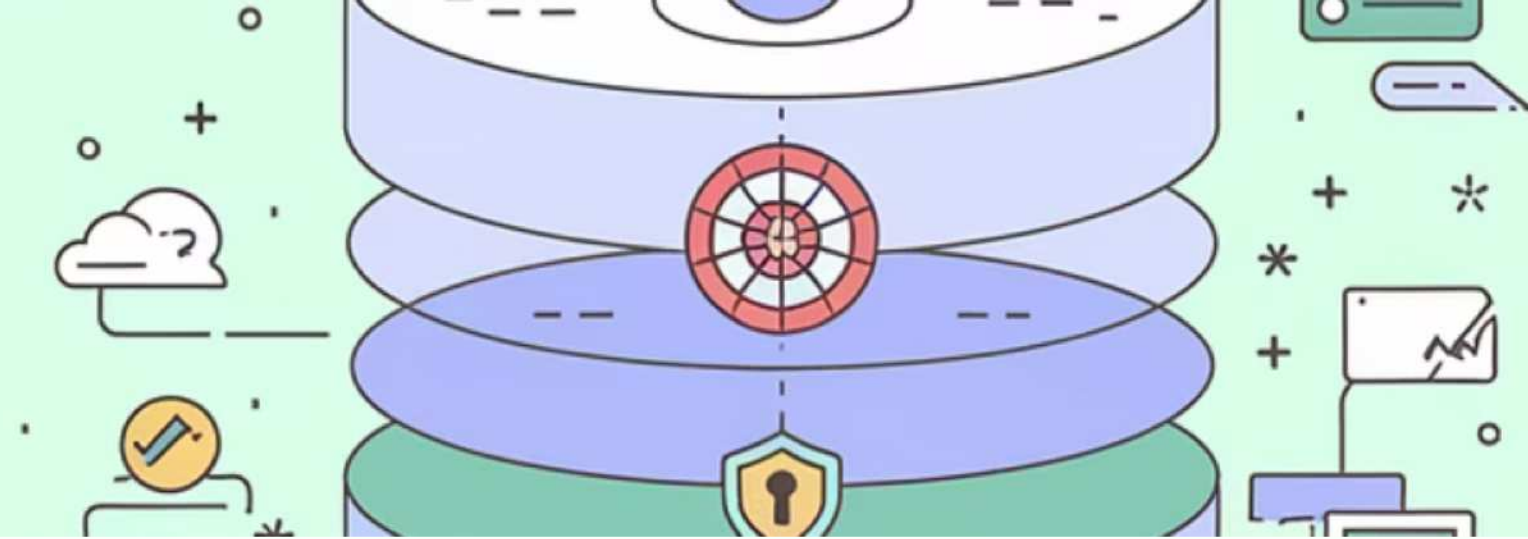
Jours

Délai d'inactivité avant expiration automatique des comptes

12

Caractères

Longueur minimale recommandée pour les mots de passe



Synthèse des mesures techniques

La directive NIS2 impose la mise en place de **mesures techniques adaptées au niveau de risque** avec un triple objectif : prévenir, détecter et réagir efficacement aux menaces.

Ces mesures couvrent plusieurs domaines essentiels pour assurer une protection complète des systèmes d'information : accès et identités, réseaux, systèmes, journalisation, chiffrement, sauvegardes, correctifs et authentification.

Prévention

Contrôle d'accès, segmentation réseau, durcissement des systèmes

Détection

Surveillance, journalisation, analyse comportementale

Réaction

Sauvegardes, plans de réponse, correctifs rapides

Sécurité des applications

Cette section explore les aspects fondamentaux de la conformité NIS2 dans le domaine applicatif, offrant un mini guide pratique pour les organisations cherchant à renforcer leur posture de sécurité et à se conformer aux nouvelles réglementations européennes.



Enjeux de la sécurité applicative

Les applications représentent une **porte d'entrée majeure** pour les **attaques** ciblant les organisations. La directive NIS2 reconnaît cette vulnérabilité et impose désormais de garantir la **sécurité du code, des composants tiers et des accès** à tous les niveaux.

L'objectif principal est triple : anticiper les failles potentielles, limiter l'exposition aux risques, et surveiller activement les comportements anormaux. Ces exigences s'appliquent à l'ensemble du périmètre applicatif : développements internes, services SaaS utilisés par l'entreprise, et toutes les API exposées.

Anticipation

Identifier et corriger les vulnérabilités avant qu'elles ne soient exploitées par des attaquants.

Limitation

Réduire la surface d'attaque et minimiser l'impact potentiel d'une compromission.

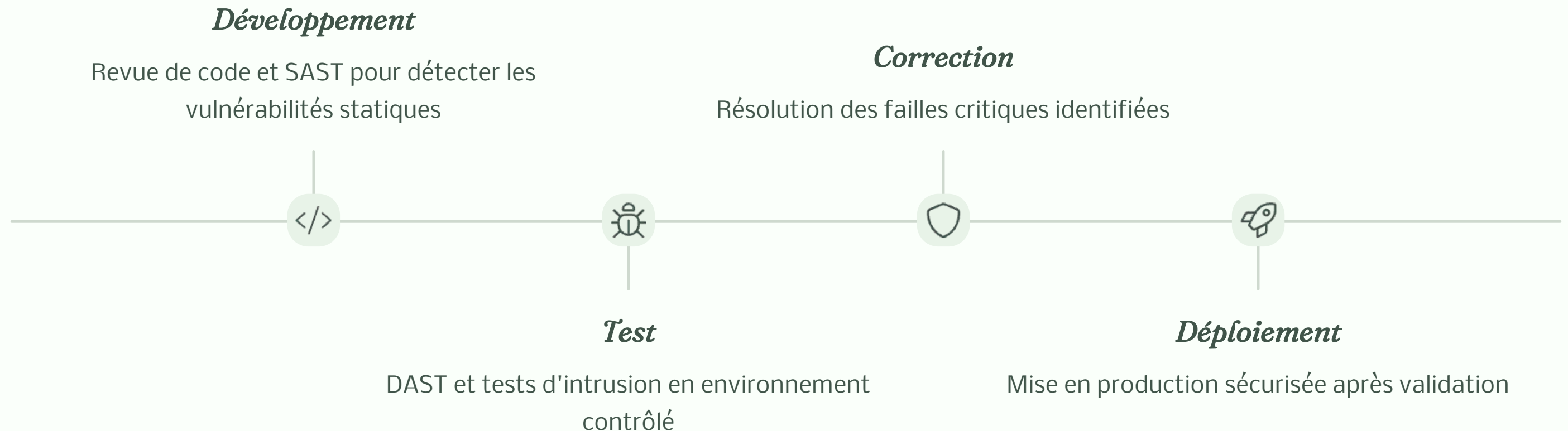
Surveillance

Détecter rapidement les comportements suspects pour une réponse efficace aux incidents.

Revue de code & tests de sécurité

La directive NIS2 exige une approche rigoureuse des tests de sécurité applicative. Le **SAST** (Static Application Security Testing) permet la détection précoce des failles lors de la compilation, tandis que le **DAST** (Dynamic Application Security Testing) évalue les vulnérabilités en environnement d'exécution.

Ces méthodes doivent être intégrées dans les pipelines DevOps (CI/CD) pour assurer une vérification continue. La correction des vulnérabilités critiques avant la mise en production devient obligatoire, tout comme la documentation exhaustive des résultats et des actions correctives entreprises.



Analyse des dépendances & SBOM

La sécurité des applications modernes repose largement sur l'intégrité des **composants open source et bibliothèques externes** qu'elles utilisent. NIS2 impose la production d'un **SBOM** (Software Bill of Materials), véritable carte d'identité logicielle listant tous les composants utilisés.

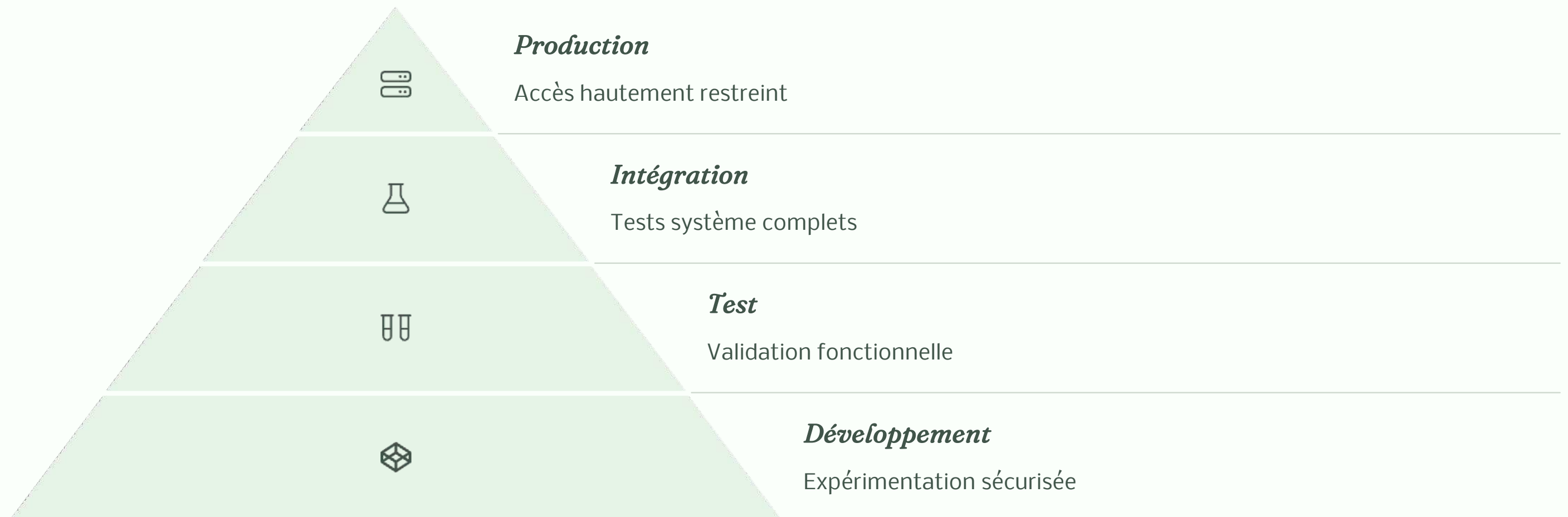
Le suivi des vulnérabilités via les bases CVE devient essentiel, tout comme l'automatisation de cette surveillance avec des outils spécialisés comme Snyk ou Dependabot. La directive interdit formellement l'utilisation de composants non maintenus ou présentant des vulnérabilités connues sans mesures compensatoires.



Séparation des environnements

NIS2 exige un cloisonnement strict entre les différents **environnements de production, développement, test et intégration**. Cette séparation constitue une barrière essentielle contre la propagation des incidents de sécurité et les erreurs humaines.

Les données de production ne doivent jamais être utilisées hors de leur environnement, tandis que les accès à chaque zone doivent être strictement limités selon les rôles des utilisateurs. Chaque environnement nécessite sa propre supervision et politique de droits, avec l'objectif clair de contenir les erreurs et d'éviter toute contamination croisée.





Gestion des secrets

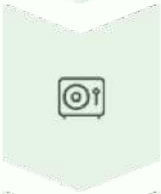
La directive NIS2 interdit formellement de stocker des **secrets en dur dans le code** (API keys, passwords, tokens), pratique malheureusement encore trop répandue. L'utilisation de **coffres-forts numériques** comme HashiCorp Vault ou AWS Secrets Manager devient obligatoire pour sécuriser ces informations sensibles.

La rotation automatique des secrets sensibles doit être mise en place, accompagnée d'un suivi rigoureux des accès via journalisation et contrôle RBAC. Le chiffrement des secrets, tant au repos qu'en transit, constitue une exigence fondamentale pour garantir leur confidentialité en toutes circonstances.



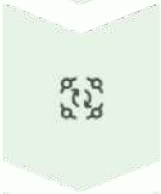
Identification

Recenser tous les secrets utilisés



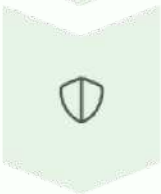
Centralisation

Migrer vers un coffre-fort sécurisé



Rotation

Renouveler automatiquement les secrets



Contrôle

Surveiller et auditer les accès

Permissions applicatives

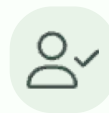
L'application du principe du **moindre privilège** devient une exigence centrale de NIS2. Chaque composant applicatif ne doit disposer que des droits strictement nécessaires à son fonctionnement, limitant ainsi l'impact potentiel d'une compromission.

Un audit régulier des permissions attribuées aux modules internes et aux utilisateurs doit être réalisé, accompagné d'une revue systématique des rôles et droits d'accès. La limitation des comptes partagés et la détection des élévations de privilège suspectes complètent ce dispositif de contrôle des permissions.



Moindre privilège

Attribuer uniquement les droits nécessaires au fonctionnement de chaque composant.



Audit régulier

Vérifier périodiquement la pertinence des permissions accordées.



Comptes individuels

Limiter l'usage des comptes partagés pour améliorer la traçabilité.



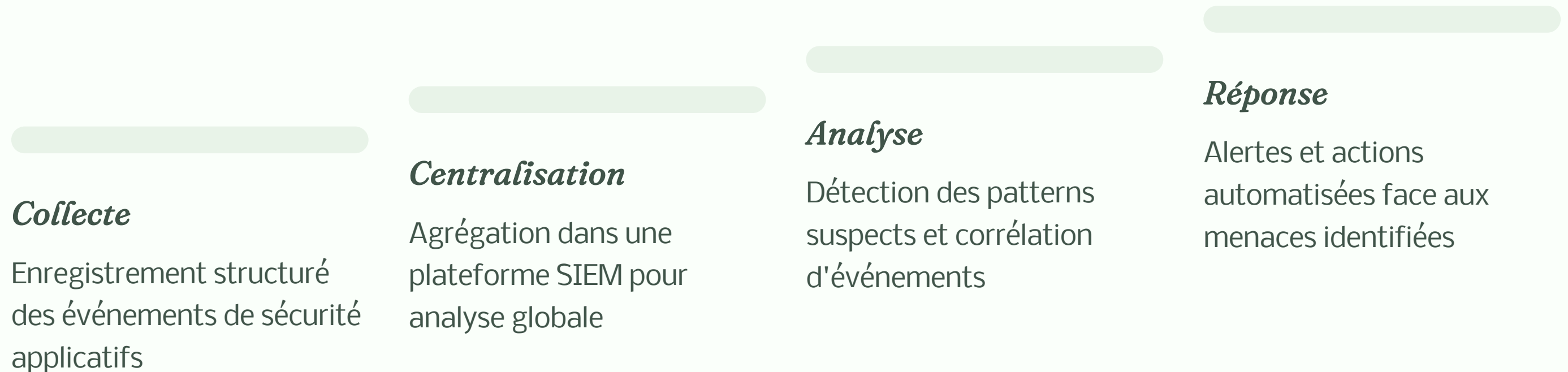
Détection d'anomalies

Identifier rapidement les tentatives d'élévation de privilèges non autorisées.

Journalisation applicative & SIEM

NIS2 impose l'enregistrement systématique des événements de sécurité au niveau applicatif, incluant les tentatives de connexion, les changements critiques et les anomalies de session. Cette journalisation doit rester conforme au RGPD, évitant notamment le stockage de données personnelles sensibles en clair.

La centralisation des journaux dans un **SIEM** (Security Information and Event Management) devient essentielle pour permettre une analyse croisée avec les événements système. Les logs doivent être conservés de manière horodatée, intègre et supervisée pour garantir leur valeur probante en cas d'incident.



Sécurité des API

Les API constituent des points d'entrée privilégiés pour les attaquants, et NIS2 exige leur protection renforcée. L'implémentation d'une **authentification forte** via des protocoles comme OAuth2 ou OpenID Connect devient obligatoire, tout comme l'application de **rate limits** pour contrer les attaques par force brute.

Le filtrage rigoureux des entrées pour prévenir les injections, le chiffrement systématique via TLS, et la surveillance en temps réel des accès complètent les mesures requises. Chaque API exposée doit être considérée comme une frontière de sécurité à part entière, nécessitant une protection adaptée à sa criticité.



Authentification

Vérification robuste de l'identité des appelants via OAuth2/OpenID



Filtrage

Validation stricte des paramètres d'entrée contre les injections



Limitation

Contrôle du volume de requêtes pour prévenir les abus



Chiffrement

Protection des données en transit via TLS

Synthèse Sécurité des applications

La sécurité applicative représente un **chaînon critique de la résilience NIS2** qui doit être adressé dès la phase de conception logicielle (shift left). L'intégration de la sécurité dans les cycles DevOps devient une nécessité, non une option.

Les organisations doivent outiller leurs développeurs et mettre en place des audits continus pour garantir la conformité. Le maintien d'un **registre de conformité et des preuves techniques** permettra de démontrer aux autorités les efforts réalisés et la maturité atteinte en matière de sécurité applicative.



Conception sécurisée

Intégrer la sécurité dès le début



Outillage adapté

Fournir les bons outils aux équipes



Automatisation

Systématiser les contrôles de sécurité



Documentation

Maintenir les preuves de conformité

Gestion des incidents & continuité

Anticiper, détecter, réagir et reprendre efficacement face aux menaces cyber est désormais une exigence fondamentale pour les organisations. La directive NIS2 impose un cadre structuré pour assurer la résilience opérationnelle des entités essentielles.

Cette section vous guidera à travers les obligations et bonnes pratiques pour mettre en place une gestion des incidents conforme et efficace, tout en garantissant la continuité de vos activités critiques.



Enjeux et contexte

Les attaques cyber sont devenues inévitables : il faut savoir y répondre efficacement. La directive NIS2 impose désormais une **réponse organisée, documentée et traçable** à ces incidents.

La gestion des incidents constitue un élément central de la conformité réglementaire et de la continuité d'activité. L'objectif est triple : **minimiser l'impact des incidents, protéger les données sensibles, et reprendre rapidement les opérations normales.**

Inévitabilité

Les attaques cyber sont devenues une réalité incontournable pour toute organisation.

Conformité

NIS2 exige une approche structurée et documentée de la gestion des incidents.

Objectifs

Minimiser l'impact, protéger les données et assurer une reprise rapide des activités.



Procédures formalisées

La mise en place d'une **procédure de gestion d'incident écrite et connue** est fondamentale pour répondre efficacement aux menaces. Cette procédure doit être claire, accessible et régulièrement mise à jour.

Les rôles et responsabilités de chaque intervenant doivent être clairement définis pour éviter toute confusion lors d'une crise et garantir une réponse coordonnée.



Détection de l'événement

Identification des anomalies et alertes de sécurité



Qualification de l'incident

Évaluation de la gravité et de l'impact potentiel



Notification des parties prenantes

Information des équipes concernées et des autorités



Contention, correction, récupération

Limitation des dégâts et restauration des systèmes



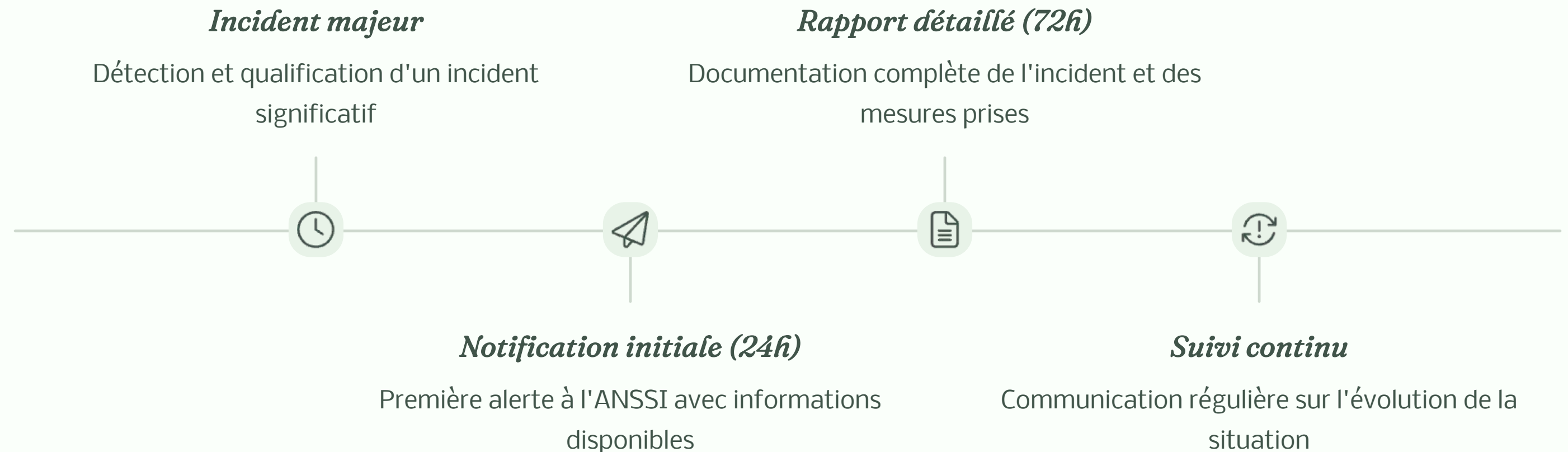
Analyse post-incident

Retour d'expérience et amélioration continue

Déclaration obligatoire sous 24h

La directive NIS2 impose l'obligation de notifier tout incident majeur dans un délai de 24h à l'autorité compétente, qui en France est l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information).

Cette notification initiale doit être suivie d'un rapport détaillé sous 72h, incluant le type d'incident, son impact, les actions en cours et les plans de remédiation. Il est également crucial de maintenir un canal d'échange avec l'autorité en cas d'évolution de la situation.



Exercices réguliers

Pour garantir l'efficacité des procédures de gestion d'incidents, des exercices de simulation réguliers sont indispensables. Ces exercices peuvent être **techniques** (simulation de ransomware, attaque DDoS) ou **organisationnels** (jeux de rôle, communication de crise).

La fréquence recommandée est d'au moins **1 exercice par an**. Ces simulations permettent d'évaluer l'efficacité des réponses, la gestion du stress et la coordination entre équipes. Les retours d'expérience doivent être intégrés dans une démarche d'amélioration continue.

Exercices techniques

- Simulation de ransomware
- Test de réponse à une attaque DDoS
- Compromission de compte privilégié
- Exfiltration de données

Exercices organisationnels

- Jeux de rôle en situation de crise
- Simulation de communication d'urgence
- Activation de la cellule de crise
- Coordination multi-équipes

Bénéfices

- Identification des faiblesses
- Amélioration des temps de réponse
- Réduction du stress en situation réelle
- Renforcement de la coordination

Registre des incidents

La tenue obligatoire d'un registre documentant tous les incidents est une exigence fondamentale de la directive NIS2. Ce registre constitue une trace formelle et chronologique des événements de sécurité et des actions entreprises.

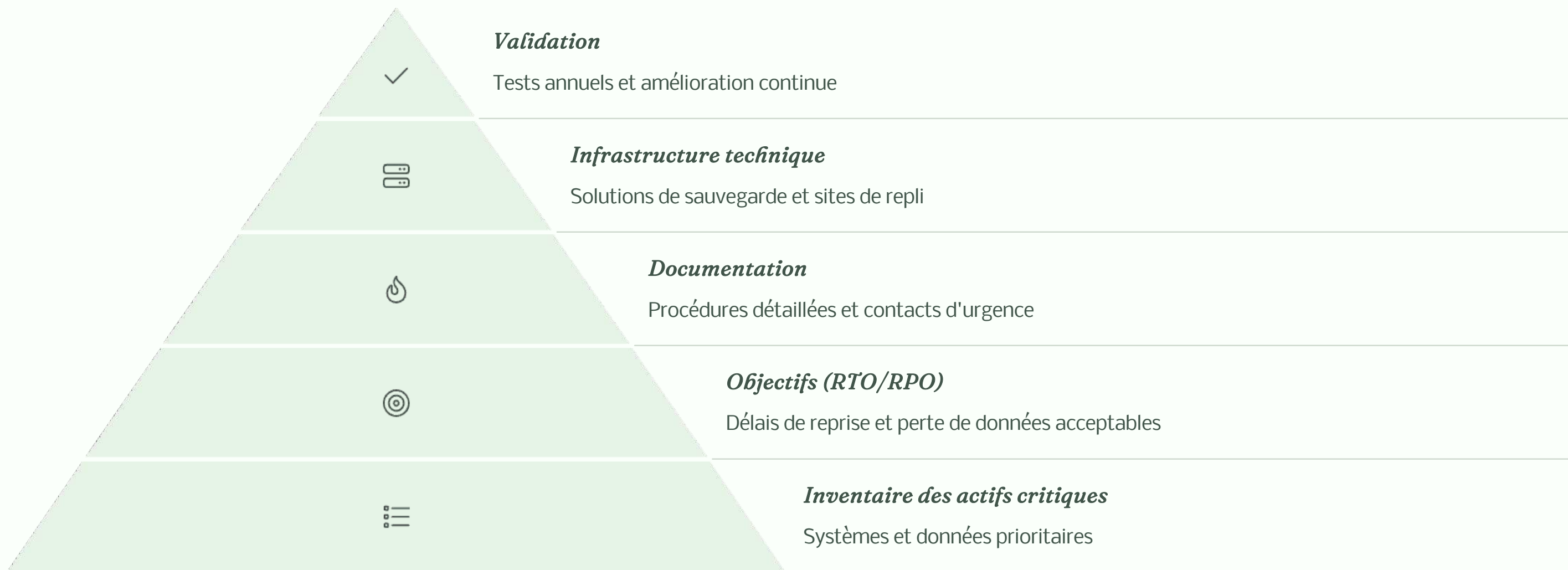
Ce document sera examiné lors des audits et pourra être requis en cas d'investigation externe. Il représente également une source précieuse d'informations pour l'amélioration continue des processus de sécurité.

Description	Nature et caractéristiques de l'incident
Horodatage	Date et heure de détection, de qualification et de résolution
Responsable	Personne en charge de la gestion de l'incident
Impact	Conséquences sur les systèmes, données et activités
Mesures prises	Actions de contention, correction et récupération
Statut de clôture	État final et leçons apprises

Plan de reprise après sinistre (PRA)

Le Plan de Reprise après Sinistre (PRA) a pour objectif de **réduire le temps d'indisponibilité** après une crise majeure. Il couvre spécifiquement la restauration des **systèmes IT, données et applicatifs** essentiels à l'activité.

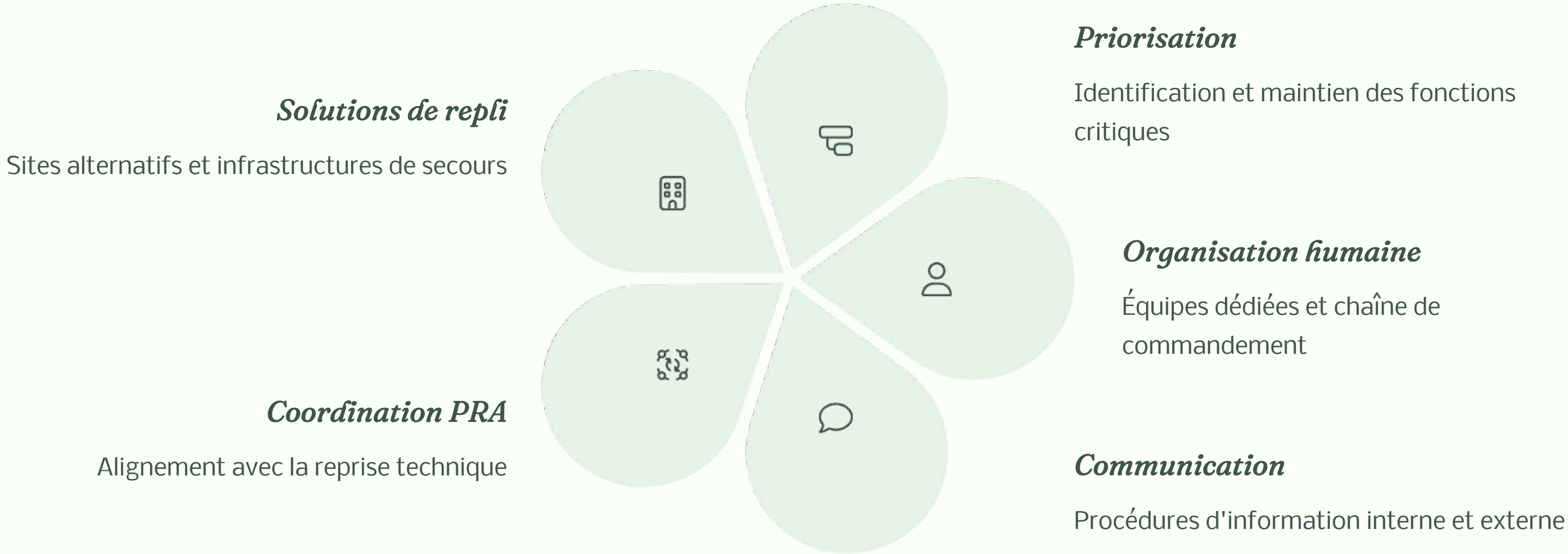
Deux indicateurs clés permettent de mesurer l'efficacité d'un PRA : le RTO (Recovery Time Objective) qui définit le délai maximal acceptable pour restaurer un système, et le RPO (Recovery Point Objective) qui détermine la perte de données maximale tolérable. Conformément aux exigences de NIS2, le PRA doit être testé au minimum **1 fois par an**.



Plan de continuité d'activité (PCA)

Le Plan de Continuité d'Activité (PCA) vise à **maintenir les services critiques** même en cas de défaillance majeure. Contrairement au PRA qui se concentre sur les aspects techniques, le PCA s'intéresse aux processus métiers essentiels de l'organisation.

Pour être efficace, le PCA doit s'articuler harmonieusement avec le PRA afin d'assurer une réponse cohérente en situation de crise. Il doit intégrer des solutions de repli, prévoir le délestage des fonctions non critiques et inclure un plan de communication adapté.



Coordination et communication

La mise en place d'un **comité de crise** ou d'une cellule d'urgence est essentielle pour coordonner efficacement la réponse aux incidents majeurs. Cette structure temporaire rassemble les compétences nécessaires pour prendre des décisions rapides et adaptées.

La communication doit être soigneusement orchestrée, tant en interne (équipes, direction, métiers) qu'en externe (régulateurs, partenaires, clients). Il est crucial de prévoir des canaux sécurisés alternatifs en cas de panne générale et de documenter rigoureusement toutes les décisions prises pendant la crise.



Comité de crise

Structure décisionnelle temporaire réunissant les compétences clés (DSI, RSSI, juridique, communication, métiers) pour piloter la réponse à l'incident.



Communication interne

Information adaptée aux différentes parties prenantes internes : équipes techniques, direction générale, collaborateurs et représentants du personnel.



Communication externe

Messages cohérents et maîtrisés vers les autorités de régulation, les partenaires commerciaux, les clients et, si nécessaire, les médias.



Traçabilité

Documentation systématique des décisions, actions et communications pour assurer la transparence et faciliter l'analyse post-crise.

Synthèse Gestion des incidents & continuité

Pour assurer la conformité avec la directive NIS2 et renforcer votre résilience opérationnelle, plusieurs éléments clés doivent être mis en place : des procédures écrites, connues et testées ; un processus de déclaration rapide et rigoureux à l'autorité compétente ; des exercices réguliers pour valider l'efficacité des plans.

Il est également essentiel de maintenir un registre des incidents à jour et de garantir une articulation cohérente entre le PRA et le PCA, alignée avec les enjeux métiers. La prochaine étape recommandée consiste à réaliser une **autoévaluation** et à organiser une **simulation réaliste** pour tester votre niveau de préparation.

Procédures formalisées

Documentation claire, accessible et régulièrement mise à jour des processus de gestion d'incidents

Déclaration conforme

Processus de notification rapide (24h) et détaillée (72h) à l'ANSSI en cas d'incident majeur

Exercices réguliers

Simulations techniques et organisationnelles au moins une fois par an

Registre des incidents

Documentation exhaustive et chronologique de tous les incidents de sécurité

PRA/PCA cohérents

Plans de reprise technique et de continuité métier alignés sur les priorités de l'organisation

Documentation & preuve de conformité

Démontrer la mise en œuvre effective des mesures de cybersécurité est essentiel pour se conformer à la directive NIS2. Cette section vous guidera à travers les exigences documentaires et les meilleures pratiques pour prouver votre conformité aux autorités compétentes.





Pourquoi documenter ?

La directive NIS2 impose une capacité à **prouver la conformité à tout moment**. Cette exigence répond à plusieurs objectifs essentiels pour votre organisation.

TM

Assurer la traçabilité

Maintenir un historique complet des actions et décisions prises.

AD

Répondre aux audits

Fournir les preuves nécessaires lors des contrôles internes ou externes.



Justifier les décisions

Démontrer la pertinence des choix techniques et organisationnels.

La documentation constitue une **preuve tangible** de la mise en œuvre effective des exigences de cybersécurité imposées par la directive.



Journalisation complète

La collecte et la conservation des **logs clés** sont obligatoires pour démontrer la conformité à la directive NIS2. Ces journaux constituent une preuve essentielle de votre vigilance.



Accès utilisateurs

Authentifications réussies ou échouées, permettant d'identifier toute tentative suspecte.



Modifications système

Changements de configuration ou mises à jour pouvant affecter la sécurité.



Tentatives d'intrusion

Détection et enregistrement des attaques potentielles contre vos systèmes.

Ces logs doivent être horodatés, intègres et centralisés pour faciliter leur analyse. Leur conservation doit s'étendre sur une période de 6 à 24 mois selon le niveau de criticité de vos systèmes.

Preuves d'audits internes & externes

Les **audits réguliers** constituent un pilier fondamental de la conformité NIS2. Ils permettent d'évaluer objectivement l'efficacité de vos mesures de cybersécurité et d'identifier les axes d'amélioration.

Audits internes

Rapports produits par le RSSI ou la DSI, évaluant la conformité aux politiques internes et aux exigences réglementaires.

Audits externes

Évaluations réalisées par des cabinets de cybersécurité indépendants ou des auditeurs spécialisés.

Certifications officielles

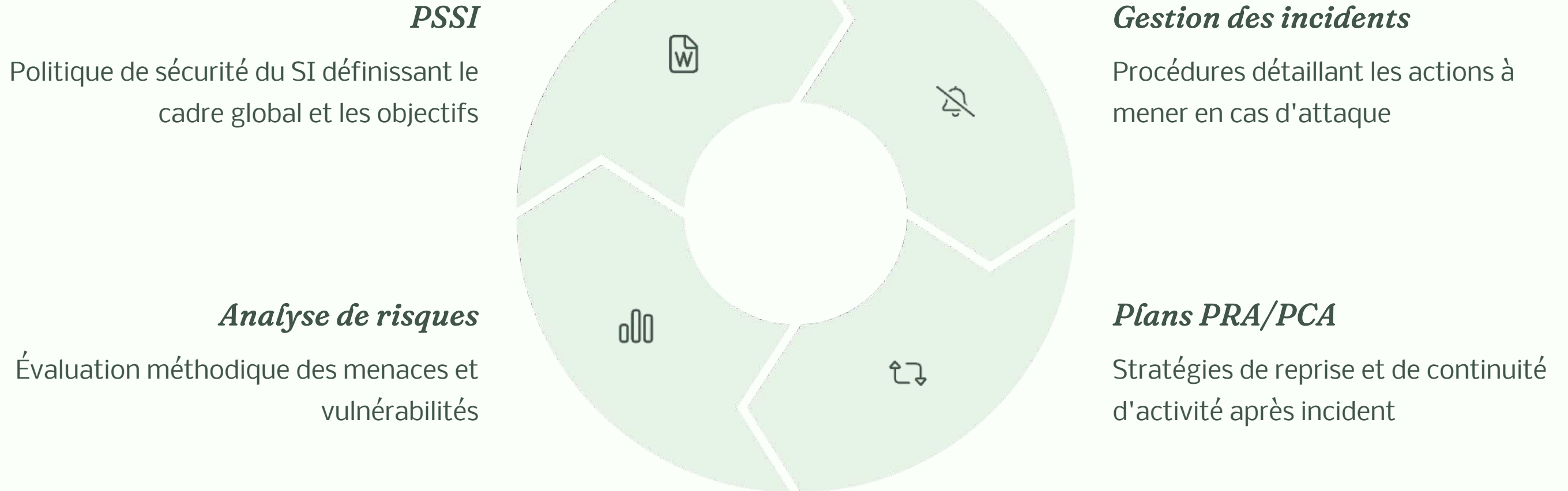
Obtention de normes reconnues comme **ISO/IEC 27001**, audit ANSSI, SecNumCloud, attestant d'un niveau de maturité.

Chaque constat d'audit doit être suivi d'un plan d'action documenté, démontrant votre engagement à remédier aux vulnérabilités identifiées.



Procédures écrites

La documentation formalisée est indispensable pour démontrer l'existence d'un cadre structuré de gestion de la cybersécurité au sein de votre organisation.



Ces documents doivent être accessibles aux parties concernées (équipes techniques, direction, métiers) et faire l'objet d'une historisation des versions avec mise à jour régulière.

Registre des vulnérabilités corrigées

La tenue d'un **registre centralisé** des vulnérabilités est essentielle pour démontrer votre capacité à gérer efficacement les failles de sécurité identifiées dans votre système d'information.

Vulnérabilité	Source	Score CVSS	Composant	Date correction	État
CVE-2023-1234	Scan auto	8.5	Serveur web	15/03/2023	Corrigé
Faillle XSS	Pentest	6.2	Applicati on RH	22/04/2023	En cours

Ce registre doit être suivi via un outil dédié ou un fichier formalisé, régulièrement mis à jour. Il constitue une preuve précieuse lors des audits ou en cas d'incident grave, démontrant votre proactivité dans la gestion des risques.



Registre de gestion des accès & rôles

La documentation rigoureuse des accès à privilèges et des attributions de rôles est fondamentale pour démontrer la maîtrise de votre périmètre de sécurité et le respect du principe du moindre privilège.



Identification

Qui a accès à quoi



Privilèges

Niveau d'accès accordé



Traçabilité

Date de création/modification/suppression



Validation

Responsable hiérarchique associé

Ce registre doit faire l'objet d'une revue régulière, idéalement tous les six mois, pour s'assurer que les droits accordés correspondent toujours aux besoins réels des utilisateurs et pour détecter d'éventuels comptes orphelins ou obsolètes.



Présentation aux autorités ou auditeurs

Tous les éléments documentés doivent être **facilement présentables** lors d'un audit ANSSI, d'un contrôle par un régulateur sectoriel ou d'une vérification de conformité suite à un incident.



La capacité à présenter rapidement une documentation complète et organisée témoigne de votre maturité en matière de gouvernance de la cybersécurité et facilite grandement les interactions avec les autorités de contrôle.



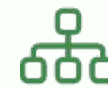
Outils & bonnes pratiques

L'adoption d'outils adaptés et de méthodologies éprouvées facilite considérablement la gestion de votre documentation de conformité NIS2.



Plateformes GRC

Solutions dédiées à la gouvernance, au risque et à la conformité, comme les référentiels ISO, Confluence ou Git.



Structuration par périmètre

Organisation logique de la documentation selon les domaines : gouvernance, technique et opérationnel.



Automatisation

Utilisation de SIEM, d'outils de gestion d'audit et de ticketing pour générer des preuves automatiquement.



Archivage sécurisé

Conservation des documents dans un environnement numérique protégé et accessible.

Synthèse documentation & preuve de conformité

Pour assurer votre conformité documentaire à la directive NIS2, plusieurs éléments clés doivent être mis en place et maintenus à jour.

Journalisation complète et centralisée

Assurez-vous que tous les logs pertinents sont collectés, horodatés et conservés pour la durée requise.

Procédures disponibles et à jour

Maintenez une documentation formalisée, accessible et régulièrement mise à jour.

Registres tenus avec rigueur

Documentez systématiquement les vulnérabilités et les accès pour démontrer votre maîtrise des risques.

Audits documentés et exploitables

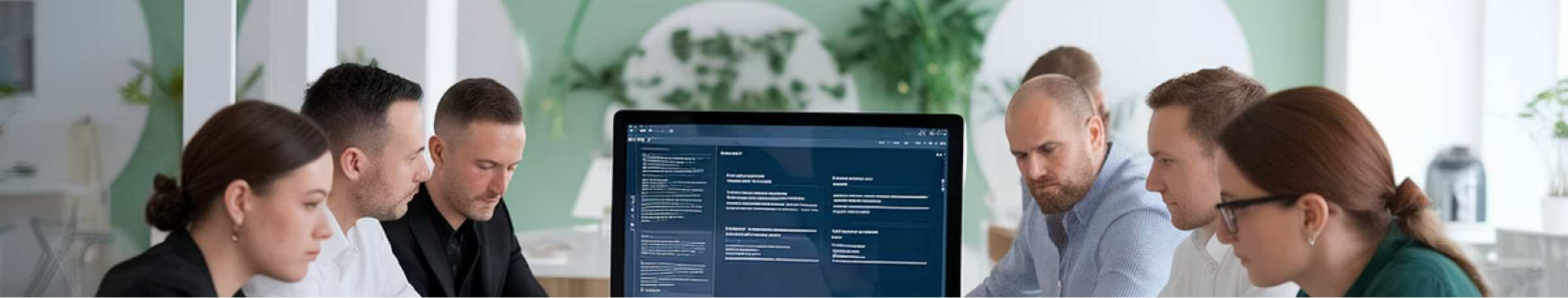
Conservez les rapports d'audit et les plans d'action associés comme preuves de votre démarche d'amélioration continue.

Prochaine étape : évaluer le niveau de maturité documentaire de votre organisation pour identifier les axes d'amélioration prioritaires et renforcer votre conformité à la directive NIS2.



Frameworks & normes pour structurer la conformité

Cette section explore les différentes normes et frameworks qui permettent aux organisations de structurer leur approche de la cybersécurité pour répondre aux exigences de la directive NIS2.



Pourquoi s'appuyer sur des normes ?



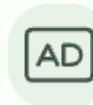
Objectifs sans méthode

NIS2 définit des objectifs de sécurité précis mais ne fournit pas de méthodologie spécifique pour les atteindre.



Structure et méthodologie

Les frameworks et normes permettent de structurer les actions, suivre une méthodologie reconnue et apporter des preuves de conformité.



Facilitation des audits

Ils facilitent les processus d'audit et contribuent à l'harmonisation des pratiques de sécurité au sein de l'organisation.

ISO/IEC 27001 & 27002

ISO 27001

Norme internationale de **management de la sécurité de l'information** qui établit un **SMSI** (Système de Management de la Sécurité de l'Information).

Elle permet de piloter les risques, gouverner les politiques, définir les responsabilités et structurer les audits de sécurité.

ISO 27002

Catalogue complet des **bonnes pratiques de sécurité**, regroupant les mesures techniques et organisationnelles essentielles.

Constitue une base solide pour répondre aux exigences NIS2 concernant la gouvernance, la gestion des risques et la documentation des processus de sécurité.

SecNumCloud

Référentiel ANSSI

Publié par l'ANSSI spécifiquement pour les prestataires cloud, ce référentiel établit des exigences strictes de sécurité pour les services d'informatique en nuage.

Exigences principales

- Localisation des données en Europe
- Souveraineté juridique garantie
- Maîtrise technique de la chaîne de service
- Chiffrement, supervision et auditabilité

Conformité NIS2

Particulièrement utile pour démontrer la conformité NIS2 dans les environnements cloud et garantir la sécurité des données externalisées.





EBIOS Risk Manager

Analyse des enjeux métier

Méthodologie d'analyse de risque publiée par l'ANSSI qui permet d'identifier les actifs critiques et de comprendre les enjeux métier liés à la sécurité de l'information.

Construction de scénarios

Élaboration de scénarios d'attaque réalistes basés sur les menaces techniques identifiées et les vulnérabilités potentielles des systèmes.

Définition des mesures

Identification des mesures de sécurité pertinentes pour réduire les risques, parfaitement adaptée aux exigences de documentation de la gestion des risques de NIS2.



CIS Benchmarks



Recommandations de durcissement

Publiées par le Center for Internet Security, ces recommandations détaillent les configurations sécurisées pour de nombreux systèmes et applications.



Large couverture

Disponibles pour Windows, Linux, VMware, bases de données, navigateurs et de nombreuses autres plateformes techniques couramment utilisées.



Standardisation

Permettent de configurer les systèmes en conformité avec les bonnes pratiques et de standardiser le durcissement à l'échelle de l'organisation.

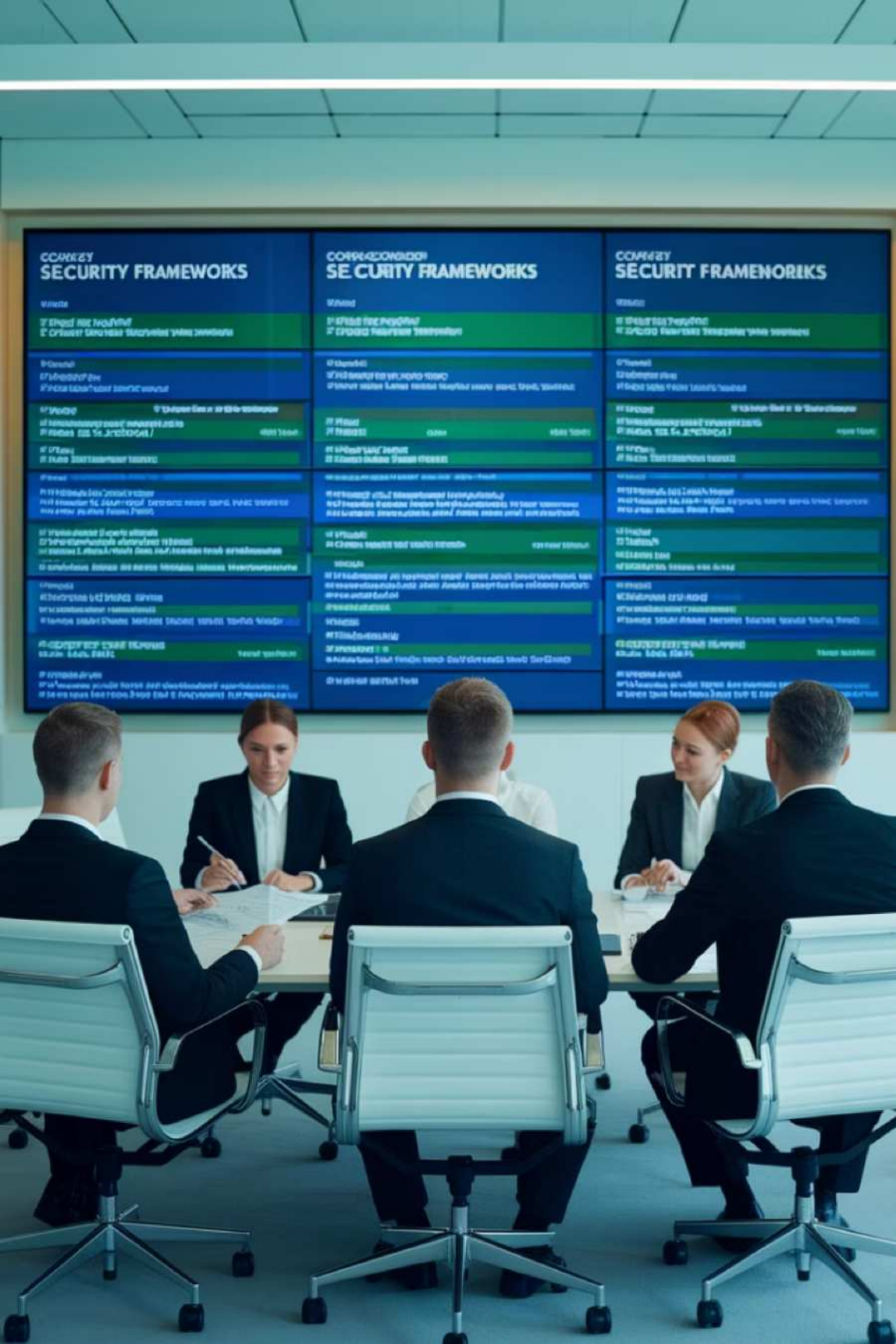
NIST Cybersecurity Framework (CSF)



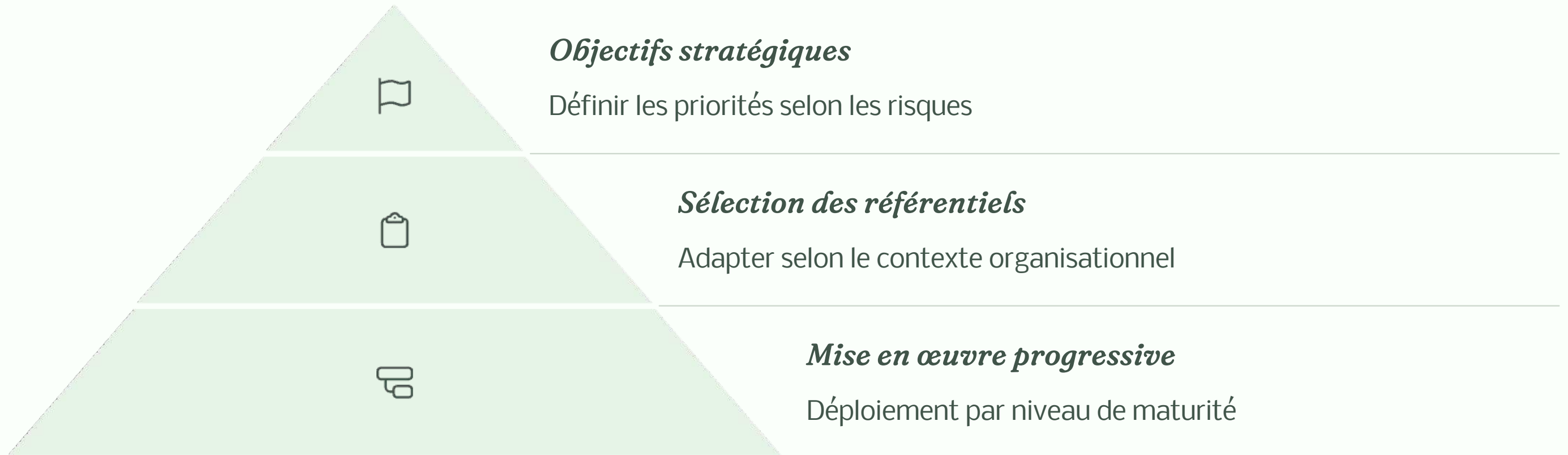
Développé par le **National Institute of Standards and Technology**, ce cadre de gouvernance est complémentaire aux normes ISO et particulièrement pédagogique pour les équipes.

Synthèse comparative

Framework / Norme	Objectif principal	Utilisation dans NIS2
ISO/IEC 27001	Management de la sécurité	Structuration, gouvernance, audit
ISO/IEC 27002	Catalogue de bonnes pratiques	Mesures techniques
SecNumCloud	Cloud souverain sécurisé	Conformité cloud
EBIOS RM	Analyse de risque	Obligations de pilotage du risque
CIS Benchmarks	Durcissement système	Configuration sécurisée des équipements
NIST CSF	Gouvernance globale de la cybersécurité	Structuration pédagogique et progressive



Intégration dans une feuille de route



Chaque organisation peut adapter son usage selon son contexte : ISO 27001 pour les grandes structures, EBIOS pour piloter le risque, CIS pour les équipes techniques. Les référentiels permettent aussi de **trouver des preuves documentées** pour les audits.

Conseil : ne pas tout appliquer d'un coup → établir des **priorités par risque et maturité** pour une mise en œuvre efficace et réaliste.

Conclusion Frameworks & normes



Réduction de l'incertitude

S'appuyer sur des normes réduit l'incertitude et facilite les contrôles



Préparation efficace

Permet de se préparer efficacement aux exigences de NIS2



Prochaines étapes

Choisir les frameworks adaptés à votre structure, cartographier les écarts, définir une feuille de route cyber cohérente

